

Attack Scenarios

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

25. Attack Scenarios

Each scenario walks through Attack → Impact → Detection → Prevention → Recovery against the proposed design, and names the requirements involved. These are analytical scenarios, not observed incidents.

Scenario 1 — Student loses ID

Attack. Meher leaves her card on the metro. A stranger finds it and, that evening, taps it at the gate. **Impact** (current system). Card is visually valid; stranger enters; no record. **Detection** (proposed). If Meher has already reported it (app → "Report lost", FR-09), the tap returns DENY–REVOKED (screen 8) and the event is flagged; supervisor alerted. If she has not yet reported it, the tap authenticates (the key is genuine); the guard sees Meher's photo (FR-12) and a stranger's face → "Mismatch" → DENY–SUSPICIOUS, flagged. **Prevention.** SEC-17 self-service revocation closes the window to minutes; FR-12/USE-05 photo check covers the gap; phone credential means Meher keeps access (no pressure on her to delay reporting). **Recovery.** Revocation is irreversible; Issuer issues a new card (FR-07); Meher's phone credential is unaffected; flagged event reviewed by Auditor.

Scenario 2 — Student gives ID to another person

Attack. Aarav lends his card to a friend from another college for the day. **Impact.** Outsider on campus under Aarav's identity; if anything happens, the log names Aarav's credential. **Detection.** Guard sees Aarav's server photo next to a different face → Mismatch (screen 16) → DENY, flagged with guard ID. If Aarav also taps his phone elsewhere within minutes, SEC-13 velocity rule flags an impossible sequence. **Prevention.** Cannot be prevented cryptographically; deterred by the visible photo check and by clear communication that entries are attributed to the credential holder (PRIV-07). Phone credentials raise the cost of lending (must hand over an unlocked phone). **Recovery.** Flagged event reviewed; institutional policy applies to Aarav; friend denied.

Scenario 3 — Attacker copies credential

Attack. TA-03 stands behind Aarav in the mess queue with a reader in a bag and reads his card. **Impact** (if MIFARE Classic / UID-based). Full clone in seconds [4, 5]; persistent access as Aarav. **Impact** (proposed). The card performs AES challenge–response with a key that never leaves the chip [41]; the sniffed exchange yields a nonce and a response, not the key. A clone with the same UID but no key → DENY–NOT RECOGNISED (screen 6). **Detection.** Repeated unknown credentials at a reader → SEC-13 escalation → SUSPICIOUS + alert. **Prevention.** SEC-01 (never accept UID), D1 (AES card family), SEC-18 (reader holds no key that would help). **Recovery.** If a chip family is later broken, Issuer re-issues that batch; revocation list handles the old cards (Section 26, stage 10).

Scenario 4 — Attacker attempts replay

Attack. TA-04 records the RF exchange during a legitimate tap and plays it back an hour later; or screenshots Meher's dynamic QR and shows it the next morning. **Impact.** None if SEC-04 holds: the recorded response answers yesterday's nonce, not today's; the QR token's timestamp is outside the window and its ID is in the replay cache. **Detection.** Reader logs a response to a stale nonce as a protocol error → DENY–SUSPICIOUS; QR with expired timestamp → DENY–NOT RECOGNISED with internal code "stale token" for the auditor. **Prevention.** Server-generated nonces (SEC-04); 30–60 s token windows with server-side dedupe; NTP (NFR-14). **Recovery.** Nothing to recover; flagged event for review. Real-time relay within the window is the residual (TH-04b).

Scenario 5 — Visitor attempts unauthorised entry

Attack. A person claims to be visiting a professor, has no pass, and pressures the guard; or forwards a friend's visitor QR. **Impact** (current). Guard writes a name in the register and lets them in, or refuses and faces an argument. **Detection** (proposed). No pass → guard opens "Visitor without approval" (screen 13); host is looked up and asked to approve from their phone (screen 14); no approval → no entry, script on screen. Forwarded pass: single-use counter (SEC-16) means the second scan is DENY; host is notified on first use, so the real visitor's arrival exposes the misuse. **Prevention.** FR-10/FR-11/SEC-16; guard has a defined procedure (FR-13) and never enters visitor data by hand. **Recovery.** Denied; host informed; pass revoked if misused.

Scenario 6 — Expired credential is presented

Attack. A graduate returns with last year's card. **Impact** (current). Guard does not read the date (H2); graduate enters. **Detection.** Authentication succeeds (genuine card), authorization fails on validity → DENY–EXPIRED (screen 7); guard sees "Expired — direct to ID cell for renewal if still a member". **Prevention.** SEC-03; validity enforced by server, cached on reader in offline mode. **Recovery.** If the person is still a member (delayed renewal), Issuer renews (lifecycle stage 9); otherwise nothing to recover.

Scenario 7 — Revoked credential is presented

Attack. A student under disciplinary suspension taps their card. **Impact** (current). Nothing on the card indicates suspension; enters. **Detection.** DENY–REVOKED (screen 8); guard sees only "Revoked — direct to Security Office"; the reason is not shown (SEC-08). **Event flagged.** **Prevention.** SEC-02; revocation pushed within 30 s; offline list. **Recovery.** If revocation was in error, a new credential is issued (SEC-17); the old one stays revoked to keep the audit trail unambiguous.

Scenario 8 — Reader/device is compromised

Attack. Overnight, TA-06 opens the reader housing, connects to a debug port, and dumps storage, hoping for master keys [36]; or replaces firmware to log every credential and return ALLOW. **Impact** (proposed). Storage yields the reader's own client certificate, public verification keys and the signed revocation list; no card keys, no identity data (SEC-18). Tamper switch logs an event; server revokes that reader's certificate; reader cannot obtain decisions. A firmware that returns ALLOW locally cannot open a gate that requires a server-signed or offline-verifiable decision (SEC-09, TH-12 control); the guard screen would show "Reader offline / tamper" (screen 10). **Detection.** Tamper event; certificate anomalies; reader failing attestation at boot (Phase 2). **Prevention.** SEC-18 (no secrets on reader), signed firmware, mutual TLS, tamper logging. **Recovery.** Replace reader; rotate its certificate; review logs for the period.

Scenario 9 — Database is compromised

Attack. TA-09 exploits an injection flaw in an admin page and dumps all tables. **Impact** (proposed). Identity table: name, roll number, programme, photo reference: a real breach but bounded by SEC-14 (no phone, address, contacts). Credential table: credential IDs, status, key references: keys themselves are in the HSM (SEC-18, PRIV-11). Logs: pseudonymous IDs (PRIV-04); the mapping table is separately controlled. Attacker cannot mint valid cards without HSM keys; cannot silently edit logs (SEC-10). **Detection.** Integrity checkpoints fail if logs were altered; DB access anomalies; ASVS controls. **Prevention.** NFR-07 (ASVS L2), parameterised queries, least-privilege DB accounts, encryption at rest. **Recovery.** Breach notification per DPDP [22]; rotate service credentials; because per-card keys were not exposed, cards need not be re-issued; if the mapping table was included, treat logs as identified and notify accordingly.

Scenario 10 — Security operator has excessive privileges

Attack. A guard account has been granted Issuer rights "for convenience". The guard issues a card to a friend, or looks up a student's entry history. **Impact.** Ghost credential; stalking. **Detection.** Issuance without roster match is refused (FR-07); if roster match exists, issuance is logged with the guard's ID and reviewable (SEC-12); re-identification of logs requires Auditor role and justification, visible to a second admin (PRIV-06). **Prevention.** SEC-07 role matrix with separation of duties makes "guard + issuer" a policy violation flagged at role assignment; MFA for admin ops (SEC-11). **Recovery.** Revoke the ghost credential; remove excess role; audit that account's actions.

25.1 Scenario coverage matrix

Scenario	Threats exercised	Requirements exercised	Screens
1 Lost ID	TH-01, TH-08	SEC-02, SEC-17, FR-09, FR-12	8, 9, 16, 18
2 Lent ID	TH-04a	FR-12, USE-05, SEC-13	5, 9, 16
3 Clone	TH-02, TH-06	SEC-01, SEC-13, SEC-18	6, 9
4 Replay	TH-03	SEC-04, NFR-14	6, 9
5 Visitor	TH-05	FR-10, FR-11, SEC-16, FR-13	13, 14, 15
6 Expired	TH-07	SEC-03	7
7 Revoked	TH-08	SEC-02, SEC-08, SEC-17	8
8 Reader	TH-16, TH-12	SEC-18, SEC-09, SEC-05	10
9 Database	TH-10, TH-15	SEC-14, PRIV-04, PRIV-11, SEC-10	19
10 Privilege	TH-09, TH-17	SEC-07, SEC-11, SEC-12, PRIV-06	17, 19

